



RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: Ms. A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on 25/11/2022. The complaint is directed against the STATE AGENCY FOR TAX ADMINISTRATION with NIF Q2826000H (hereinafter, the complained party). The reasons on which the complaint is based are as follows: the complainant believes that the complained party has violated the regulations on personal data protection by sending her tax data (income tax return for the year 2019) to a third party without it being established that he holds her representation.

On 14/10/22, the affected party addressed the complained party by means of a written communication indicating that her tax settlement had been incorrectly sent to her nephew, with whom she has no relationship, and who is not her representative.

On 17/10/22, the third party notified by the complained party submitted a written statement informing that he does not represent the complainant.

On 28/10/22, the complained party sent a notification to the complainant, indicating the background and agreeing to rectify the administrative act in question, thereby annulling the settlement subject to challenge and canceling the associated sanctioning file.

A copy of the previous documents is attached to the complaint.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and the Guarantee of Digital Rights (hereinafter LOPDGDD), on 30/01/2023, the aforementioned complaint was forwarded to the complained party for analysis and to inform this Agency within one month of the actions taken to comply with the requirements established in the data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on 30/01/2023 as evidenced by the acknowledgment of receipt in the file.

THIRD: On 25/02/2023, in accordance with Article 65 of the LOPDGDD, the complaint submitted by the complainant was admitted for processing.

FOURTH: On 19/04/2023, the Director of the Spanish Agency for Data Protection decided to initiate a sanctioning procedure against the complained party for the alleged violations of Articles 5.1.f) and 32.1 of the GDPR, classified in Articles 83.5.a) and 83.4.a) of the GDPR, sanctioning with a warning in accordance with the provisions of Article 77 of the LOPDGDD.

FIFTH: After notification of the initiation agreement, the complained party submitted a written statement of allegations on 03/05/2023, stating, in summary: assurance of the security of the notification and communication system; that the error occurred at a time prior to the notification when the registration of successors was made; protocol for registration of successors: the complained party describes the incident that occurred and states that it was due to a specific human error and that the security measures are established in accordance with the risk analyses carried out and aligned with the detected risk; admission for processing of the complaint: it is not understood why it was admitted for processing when a response had not yet been received from the AEAT and it was still within the deadline for sending such a response; that specific human errors cannot be controlled.

SIXTH: On 23/05/2023, a period for the practice of evidence was initiated, agreeing to the following:

- To consider reproduced for evidentiary purposes the complaint filed by the complainant and its documentation, the documents obtained and generated by the Inspection Services that are part of the file.
- To consider reproduced for evidentiary purposes the allegations to the initiation agreement presented by the complained party and the documentation accompanying them.

SEVENTH: On 11/07/2023, a Proposal for Resolution was issued stating that the Director of the

Spanish Agency for Data Protection should sanction the complained party for the infringement of Articles 5.1.f) and 32.1 of the GDPR, classified in Articles 83.5.a) and 83.4.a) of the aforementioned GDPR, with respective warnings.

On 24/07/2023, the complained party submitted a written statement of allegations stating, in summary: that the GDPR does not require absolute security but rather that appropriate measures be applied to ensure an adequate level of security; that the complained party has risk analyses that are constantly reviewed and updated; that as soon as the error was known, action was taken with the utmost diligence to terminate the relationship; that the incident was due to human error and not to a lack of diligence in the measures implemented, considering it necessary to emphasize awareness to avoid such errors.

EIGHTH: From the actions carried out in this procedure, the following have been established:

PROVEN FACTS

FIRST. The complainant, by means of a written communication dated 25/11/2022, filed a complaint against the complained party, stating that the complained entity has violated the regulations on personal data protection by sending her tax data (income tax return for the year 2019) to a third party and nephew of the complainant without it being established that he holds her representation.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/12

SECOND. It is recorded that a document has been submitted by Mr. B.B.B., nephew of the claimant, dated 03/10/2022 addressed to the respondent, in which he informs that he has received notification regarding allegations and a proposal for provisional settlement concerning IRPF 2019, in his capacity as representative of the claimant, which contains personal data and attaches the notification for said tax concept.

THIRD. The claimant provides a copy of the document sent to the respondent on 14/10/2022, in which she informs of the facts submitted to the knowledge of the AEPD, without any response from the respondent according to the affected party.

FOURTH. There is an Agreement of initiation and communication of the hearing procedure of the sanctioning file motivated by the failure to respond to the proposal for provisional settlement concerning IRPF 2019, which was sent to Mr. B.B.B.

FIFTH. An Agreement of Resolution for Rectification of Errors dated 28/10/2022 has been submitted, in which it is stated in the resolute part that the notification made was erroneously sent to another taxpayer in the capacity of representative of the claimant, therefore the notification was annulled, the act of the notification was rectified, the provisional settlement was annulled, and the sanctioning procedure was terminated.

SIXTH. The respondent in a document dated 03/03/2023 has stated that “At the time of sending the information referred to by the claimant (‘Informative Note’ containing the ‘Notification of the allegations procedure and proposal for provisional settlement’), the third party involved (...) was recorded as the successor of the claimant in the successor registry of the Tax Agency, thus, as established by the regulations, the documentation was sent to said successor.”

LEGAL GROUNDS

I

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, insofar as they do not contradict

them, subsidiarily by the general rules on administrative procedures.”

II

The reported facts are specified in the notification carried out by the respondent directed to a third party, transferring tax documentation corresponding to the claimant without any authorization or consent being recorded, nor does he hold her representation.

Article 58 of the GDPR, Powers, states:

“2. Each supervisory authority shall have all of the following corrective powers:

(...)

b) to impose an administrative fine on the controller or processor with a warning when the processing operations have infringed the provisions of this Regulation;

(...)

d) to order the controller or processor to bring processing operations into compliance with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time;

(...)”

III

The processing carried out constitutes an infringement of Article 5, Principles relating to processing, of the GDPR, which establishes that:

“1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures (‘integrity and confidentiality’).

(...)”

IV

Article 83.5 a) of the GDPR considers that the infringement of “the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9” is subject to sanction.

On the other hand, the LOPDGDD, for the purposes of prescription, in its Article 72 states:

“Very serious infringements:

1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and shall prescribe after three years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679.

(...)”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/12

V

1. The documentation in the file evidences that the respondent violated Article 5 of the GDPR, principles relating to processing, by allowing access to personal data by a third party who was notified of the tax settlement of the claimant without it being recorded that they held their representation, nor that their authorization for this was documented. The duty of confidentiality must be understood as having the purpose of preventing unauthorized leaks of data by the data subjects.

Therefore, this duty is an obligation that falls not only on the data controller and processor but also on anyone involved in any phase of the processing and is complementary to the duty of professional secrecy.

2. The respondent has acknowledged that “At the time of sending the information referred to by the claimant (“Informative Note” containing the “Notification of the procedure for allegations and proposal for provisional settlement”), the third party involved (B.B.B.) was recorded as the successor of the claimant in the successor registry of the Tax Agency, thus, as established by the regulations, the

documentation was sent to said successor. That “On October 17, 2022, the writing from the third party involved (B.B.B.) was registered with the Tax Agency, indicating that they did not represent the claimant. After analyzing the facts and the possible causes of the error, on October 18, 2022, the successor registry was corrected. The error was due to the fact that, ..., the relationship between the third party involved and the claimant (aunt of the third party involved) was registered in the successor registry, following internal protocol, instead of the relationship between the third party involved and the claimant's deceased mother (C.C.C., grandmother of the third party involved), due to confusing the ID number of the deceased mother with that of the daughter. The third party involved was the grandson of the deceased and her successor, since the father of the third party involved and son of the deceased had also passed away.” And that “Although a specific human error cannot be controlled, it is planned to send a reminder about the protocol for registration in the successor registry, emphasizing the verification and review of all information included before registration.” The actions of the respondent evidence the violation of the principle of confidentiality, in accordance with the provisions of Article 5.1.f), an infringement classified in Article 83.5.a) of the aforementioned Regulation.

VI

Secondly, the respondent is attributed with the infringement of Article 32 of the GDPR “Security of processing,” which establishes that:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law.”

VII

The violation of Article 32 of the GDPR is classified in Article 83.4.a) of the aforementioned GDPR in the following terms:

“4. Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to a maximum of 2% of the total annual global turnover of the preceding financial year, opting for the higher amount:

- a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43. (...)”

For its part, the LOPDGDD in its Article 71, Infringements, states that:

“Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

C/ Jorge Juan, 6

www.aepd.es

Y in its Article 73, for the purposes of prescription, qualifies as “Serious Offenses”:

“According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a two-year limitation period for violations that constitute a substantial breach of the articles mentioned therein and, in particular, the following:

(...)

g) The breach, as a consequence of a lack of due diligence, of the technical and organizational measures that should have been implemented in accordance with the requirements of Article 32.1 of Regulation (EU) 2016/679.”

(...)

VIII

1. The GDPR defines personal data security breaches as “all breaches of security that lead to the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or to the unauthorized communication or access to such data.”

The documentation in the file provides clear evidence that the respondent has violated Article 32 of the GDPR, as a security incident occurred, breaching the technical and organizational measures.

It should be noted that the GDPR in the aforementioned provision does not establish a list of security measures applicable according to the data being processed, but rather states that the data controller and the processor shall apply technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of likelihood and severity for the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of technical and organizational measures should be made considering: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification process (which is not an audit), evaluation, and assessment of the effectiveness of the measures.

In any case, when assessing the adequacy of the level of security, particular attention shall be paid to the risks presented by the processing of data, as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In this same sense, Recital 83 of the GDPR states that:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/12

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the inherent risks of the processing and apply measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be considered, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, particularly those that may cause physical, material, or immaterial harm.”

2. In the present case, as stated in the facts and in the context of the investigation file, the AEPD forwarded the complaint to the respondent on 31/01/2023 for analysis and to inform this Agency of the actions taken to comply with the requirements set forth in data protection regulations; although the

respondent stated in a written submission regarding the initiation agreement dated 03/05/2023 that they did not understand why the complaint was accepted for processing when a response had not yet been received from the AEAT, the fact is that it was received outside the established deadline, on 03/03/2023. As noted in the third Background, the complaint was accepted on 25/02/2023, after the response period had elapsed and in accordance with Article 65 of the LOPDGDD.

On the other hand, in the aforementioned document, the respondent stated that the events had been reviewed and that the notification sent complied with the established regulations, as the sending was made to a person registered as a successor, and although it was all due to a specific human error, the change in the register of successors at the time it was known is also appropriate.

However, the respondent continues to indicate that "The error was due to the fact that, ..., the relationship between the third party involved and the complainant (aunt of the third party involved) was registered as a successor, following the internal protocol, instead of the relationship between the third party involved and the complainant's deceased mother (... , grandmother of the third party involved), due to confusing the ID number of the deceased mother with that of the daughter.

The third party involved was the grandson of the deceased and her successor, since the father of the third party involved and son of the deceased had also passed away (...)."

Furthermore, the respondent has stated that they plan to send a reminder regarding the registration protocol for successors, emphasizing the verification and review of all information included before registration.

In their submissions to the Proposal, the respondent has provided a Reminder of the considerations to be taken into account to avoid incidents when proceeding with the registration.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/12

registration in the Succession Registry with the guidelines to follow before proceeding with the registration.

On the other hand, it should be noted that the liability of the respondent is determined by the failure to adopt measures that prevent errors such as the one that occurred, as they are responsible for making decisions aimed at effectively implementing and adapting the appropriate technical and organizational measures to ensure an adequate level of security relative to the risk to guarantee the confidentiality of the data, restoring its availability and preventing access to it in the event of a physical or technical incident.

In accordance with the above, it is estimated that the respondent would be presumably liable for the infringement of the GDPR: the violation of Article 32, an infringement classified in Article 83.4.a).

IX

The LOPDGDD in its Article 77, Applicable regime for certain categories of controllers or processors, establishes the following:

"1. The regime established in this article shall apply to the processing for which they are responsible or processors:

- a) The constitutional bodies or those with constitutional relevance and the institutions of the autonomous communities analogous to them.
- b) The judicial bodies.
- c) The General Administration of the State, the Administrations of the autonomous communities, and the entities that make up the Local Administration.
- d) The public bodies and entities of public law linked to or dependent on the Public Administrations.
- e) The independent administrative authorities.
- f) The Bank of Spain.
- g) The public law corporations when the purposes of the processing relate to the exercise of public law powers.
- h) The public sector foundations.

i) The Public Universities.

j) The consortiums.

k) The parliamentary groups of the General Courts and the autonomous Legislative Assemblies, as well as the political groups of the Local Corporations.

2. When the controllers or processors listed in section 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or correct the effects of the infringement that has been committed. The resolution shall be notified to the controller or processor of the processing, to the body to which they hierarchically depend, if applicable, and to the affected parties who had the status of interested parties, if applicable.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/12

3. Without prejudice to what is established in the previous section, the data protection authority shall also propose the initiation of disciplinary actions when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regime that is applicable.

Likewise, when the infringements are attributable to authorities and executives, and the existence of technical reports or recommendations for the processing that have not been duly addressed is accredited, the resolution imposing the sanction shall include a reprimand naming the responsible position and shall order the publication in the Official State Gazette or the corresponding autonomous gazette.

4. The resolutions relating to the measures and actions referred to in the previous sections must be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article shall be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities.

6. When the competent authority is the Spanish Agency for Data Protection, it shall publish on its website with due separation the resolutions related to the entities in section 1 of this article, with an express indication of the identity of the controller or processor who has committed the infringement. When the competence corresponds to an autonomous data protection authority, the publicity of these resolutions shall be governed by its specific regulations.”

In the case examined, the present sanctioning procedure arises because the respondent, as stated in the proven facts, has violated the regulations regarding the protection of personal data both of the principle of confidentiality of the data and the security measures implemented.

Such conduct constitutes, on the part of the respondent, the infringement of the provisions of Articles 5.1.f) and 32.1 of the GDPR.

It should be noted that the GDPR, without prejudice to what is established in its Article 83, contemplates in its Article 77 the possibility of resorting to the sanction of warning to correct the processing of personal data that do not comply with its provisions, when the controllers or processors listed in section 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/12

Additionally, Article 58 of the GDPR, in its paragraph 2 d), states that each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame...”.

However, the respondent has indicated that it has IT risk analyses that are constantly reviewed and updated; that the technical and organizational measures to be applied are the result of annual project plans, which are informed by both the results of the specified IT risk analysis and management, as well as the organization's Risk Maps, applicable regulations, and any projects deemed necessary to address.

And although the incident was due to human error, it considers it necessary to emphasize awareness to mitigate and avoid such incidents as much as possible, providing, as noted, a Reminder of the considerations to take into account to avoid incidents in the registration of Successors with the guidelines to follow before proceeding with the registration.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

The Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on the STATE AGENCY FOR TAX ADMINISTRATION, with NIF Q2826000H, for violations of Articles 5.1.f) and 32.1 of the GDPR, classified under Articles 83.5.a) and 83.4.a) of the GDPR, a warning sanction for each of them.

SECOND: TO NOTIFY this resolution to the STATE AGENCY FOR TAX ADMINISTRATION.

THIRD: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative process in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the final resolution in the administrative process may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency does not become aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension to be concluded.

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es